

KHOA: CÔNG NGHỆ THÔNG TIN / AN TOÀN THÔNG TIN

BÁO CÁO ĐỒ ÁN

XÂY DỰNG HỆ THỐNG NGĂN CHẶN XÂM NHẬP (IPS) SỬ DỤNG SNORT 3

Giảng viên hướng dẫn

Lóp

Đà Nẵng, năm 2026

MỤC LỤC

Nhấn Ctrl + A rồi F9 trong Microsoft Word để cập nhật mục lục tự động.

TÓM TẮT ĐỀ TÀI

Đề tài tập trung nghiên cứu và xây dựng một hệ thống ngăn chặn xâm nhập mạng (Intrusion Prevention System - IPS) dựa trên Snort 3. Hệ thống được triển khai trong môi trường lab gồm máy tấn công, máy nạn nhân và máy Snort đặt ở vị trí trung gian để giám sát, phát hiện và chặn lưu lượng độc hại.

Báo cáo trình bày cơ sở lý thuyết về IDS/IPS, kiến trúc Snort 3, thiết kế mô hình mạng, các bước cài đặt - cấu hình, cách viết rule và một số kịch bản demo phổ biến như phát hiện ICMP, port scanning, SSH brute force, SQL Injection và chặn gói tin bằng rule drop ở chế độ inline.

1. GIỚI THIỆU CHUNG

1.1. Lý do chọn đề tài

Trong bối cảnh hệ thống mạng ngày càng phức tạp, các cuộc tấn công như quét cổng, dò mật khẩu, khai thác ứng dụng web và tấn công từ chối dịch vụ xuất hiện thường xuyên hơn. Nếu chỉ sử dụng tường lửa truyền thống, hệ thống có thể chưa phát hiện được các hành vi tấn công ẩn trong lưu lượng hợp lệ.

Snort 3 là một công cụ IDS/IPS mã nguồn mở, có khả năng phân tích gói tin, phát hiện mẫu tấn công dựa trên rule và hoạt động ở chế độ inline để ngăn chặn lưu lượng nguy hiểm. Vì vậy, Snort 3 phù hợp để xây dựng một mô hình IPS phục vụ học tập, nghiên cứu và demo thực tế.

1.2. Mục tiêu đề tài

Tìm hiểu khái niệm IDS, IPS và vai trò của IPS trong bảo vệ hệ thống mạng.

Nghiên cứu kiến trúc và cơ chế hoạt động của Snort 3.

Triển khai Snort 3 trong môi trường lab và cấu hình hoạt động ở chế độ IDS/IPS.

Xây dựng rule phát hiện, cảnh báo và chặn một số hành vi tấn công cơ bản.

Thực hiện demo, ghi nhận kết quả và đánh giá ưu nhược điểm của hệ thống.

1.3. Phạm vi nghiên cứu

Đề tài triển khai trong mạng nội bộ mô phỏng bằng máy ảo. Các kịch bản tấn công được thực hiện trong môi trường lab nhằm mục đích học tập.

Các nội dung tập trung vào Snort 3, rule tùy chỉnh, chế độ cảnh báo và chế độ inline. Báo cáo không đi sâu vào triển khai quy mô doanh nghiệp lớn, tối ưu hiệu năng chuyên sâu hoặc tích hợp đầy đủ với SIEM.

1.4. Kết quả dự kiến

Xây dựng được mô hình IPS hoạt động trong lab.

Snort có thể phát hiện lưu lượng ICMP, quét cổng, brute force SSH và payload SQL Injection cơ bản.

Snort có thể chặn gói tin khi sử dụng rule drop ở chế độ inline.

Nhóm có tài liệu hướng dẫn triển khai và kịch bản demo phục vụ thuyết trình.

2. CƠ SỞ LÝ THUYẾT

2.1. Tổng quan về an ninh mạng

An ninh mạng là tập hợp các biện pháp kỹ thuật và quản trị nhằm bảo vệ hệ thống, dữ liệu và dịch vụ trước các nguy cơ truy cập trái phép, thay đổi dữ liệu, gián đoạn dịch vụ hoặc đánh cắp thông tin.

Ba mục tiêu cơ bản của bảo mật thông tin gồm: tính bí mật (Confidentiality), tính toàn vẹn (Integrity) và tính sẵn sàng (Availability).

2.2. Một số dạng tấn công phổ biến

Port scanning: kẻ tấn công quét cổng để tìm dịch vụ đang mở, từ đó xác định mục tiêu khai thác.

Brute force: thử nhiều tổ hợp tài khoản/mật khẩu để đăng nhập trái phép vào dịch vụ như SSH, FTP, web login.

SQL Injection: chèn câu lệnh SQL vào tham số đầu vào của ứng dụng web để đọc, sửa hoặc phá hoại dữ liệu.

DoS/DDoS: gửi lưu lượng lớn hoặc khai thác điểm yếu giao thức nhằm làm gián đoạn dịch vụ.

2.3. IDS và IPS

IDS (Intrusion Detection System) là hệ thống phát hiện xâm nhập. IDS giám sát lưu lượng, so khớp dấu hiệu tấn công và sinh cảnh báo nhưng thường không trực tiếp chặn lưu lượng.

IPS (Intrusion Prevention System) là hệ thống ngăn chặn xâm nhập. IPS đặt trên đường truyền hoặc kết hợp với cơ chế điều khiển gói tin để phát hiện và chặn lưu lượng nguy hiểm theo thời gian gần thực.

2.4. So sánh IDS và IPS

Tiêu chí	IDS	IPS
Vị trí triển khai	Giám sát lưu lượng, thường đặt ngoài luồng	Đặt inline hoặc can thiệp trực tiếp vào luồng gói tin
Hành động	Cảnh báo, ghi log	Cảnh báo, ghi log và chặn/drop gói tin
Rủi ro	Ít ảnh hưởng đường truyền	Có thể ảnh hưởng lưu lượng nếu cấu hình sai
Mục đích	Phân tích, phát hiện	Phòng thủ chủ động

2.5. Nguyên lý hoạt động của IPS

Một IPS thường thu thập gói tin từ card mạng, giải mã giao thức, phân tích nội dung, so khớp với rule hoặc mẫu hành vi, sau đó quyết định cho phép, cảnh báo hoặc chặn lưu lượng.

Quy trình tổng quát gồm: thu thập gói tin -> giải mã gói tin -> tiền xử lý -> phát hiện -> phản hồi -> ghi log/cảnh báo.

2.6. Giới thiệu Snort 3

Snort 3 là thế hệ mới của Snort, được thiết kế lại với cấu hình linh hoạt hơn, kiến trúc module rõ ràng hơn và hỗ trợ tốt hơn cho việc mở rộng.

Snort có thể hoạt động ở nhiều chế độ: sniffer để quan sát gói tin, packet logger để ghi gói tin, IDS để phát hiện/cảnh báo và IPS inline để chặn gói tin.

2.7. Kiến trúc Snort 3

- DAQ (Data Acquisition): lớp thu thập gói tin từ interface, pcap, NFQUEUE hoặc AFPacket.
- Packet Decoder: giải mã Ethernet, IP, TCP, UDP, ICMP và các giao thức liên quan.
- Preprocessor/Inspector: phân tích sâu từng loại giao thức hoặc dịch vụ như HTTP, DNS, SSH.
- Detection Engine: so khớp lưu lượng với rule.
- Output/Logging: ghi cảnh báo, log sự kiện và xuất kết quả ra console/file.

3. THIẾT KẾ HỆ THỐNG

3.1. Mô hình mạng đề xuất

Mô hình lab gồm ba máy chính: máy Attacker dùng Kali Linux, máy Victim dùng Ubuntu Server hoặc Windows Server, và máy Snort IPS dùng Ubuntu đặt ở giữa để giám sát/chặn lưu lượng.

```
Attacker (Kali Linux) ----> Snort IPS ----> Victim Server
192.168.56.10          192.168.56.1/24  192.168.56.20
                        192.168.57.1/24
```

3.2. Vai trò từng máy

Thành phần	Hệ điều hành	IP gợi ý	Vai trò
Attacker	Kali Linux	192.168.56.10	Sinh lưu lượng tấn công: ping, nmap, hydra, payload web
Snort IPS	Ubuntu Server	2 card mạng	Chạy Snort 3, đặt inline, cảnh báo và chặn gói tin
Victim Server	Ubuntu/Windows	192.168.57.20	Chạy SSH, Apache/DVWA hoặc dịch vụ mục tiêu

3.3. Công cụ sử dụng

- Snort 3: công cụ IDS/IPS chính.
- Kali Linux: máy tấn công phục vụ demo.
- Nmap: quét cổng và kiểm tra dịch vụ.
- Hydra: mô phỏng brute force SSH trong lab.
- Apache/DVWA: môi trường web dễ bị tấn công để demo SQL Injection.
- Wireshark hoặc tcpdump: quan sát gói tin khi cần kiểm chứng.

3.4. Luồng hoạt động của hệ thống

1. Gói tin từ Attacker đi qua máy Snort IPS.
2. Snort sử dụng DAQ để nhận gói tin từ luồng mạng.
3. Detection Engine so khớp gói tin với các rule đã cấu hình.
4. Nếu rule là alert, Snort ghi cảnh báo nhưng vẫn cho gói tin đi qua.
5. Nếu rule là drop trong chế độ inline, Snort chặn gói tin và ghi nhận sự kiện.

4. TRIỂN KHAI SNORT 3

4.1. Chuẩn bị môi trường

Máy Snort nên sử dụng Ubuntu Server/Desktop. Cần cập nhật hệ thống và cài đặt các gói phụ thuộc trước khi biên dịch hoặc cài đặt Snort 3.

```
sudo apt update && sudo apt upgrade -y
```

```
sudo apt install -y build-essential cmake make gcc g++ git flex bison libpcap-dev libpcap3-dev libdumbnet-dev zlib1g-dev liblzma-dev openssl libssl-dev pkg-config hwloc libhwloc-dev lua5.1-dev
```

4.2. Cài đặt Snort 3

Có thể cài Snort 3 từ source để chủ động phiên bản và cấu hình. Các bước dưới đây là khung triển khai, nhóm cần điều chỉnh theo hệ điều hành và phiên bản thực tế.

```
git clone https://github.com/snort3/snort3.git
cd snort3
./configure_cmake.sh --prefix=/usr/local --enable-tcmalloc
cd build
make -j$(nproc)
sudo make install
snort -V
```

4.3. Cấu hình Snort

File cấu hình chính thường là snort.lua. Trong đồ án, nhóm nên tạo thư mục riêng để lưu rule tự viết, ví dụ /usr/local/etc/snort/rules/local.rules.

```
sudo mkdir -p /usr/local/etc/snort/rules
sudo touch /usr/local/etc/snort/rules/local.rules
sudo nano /usr/local/etc/snort/snort.lua
```

Lưu ý: Trong snort.lua cần khai báo biến mạng HOME_NET phù hợp với dải mạng lab và include file local.rules để Snort nạp rule tự viết.

4.4. Kiểm tra cấu hình

```
sudo snort -c /usr/local/etc/snort/snort.lua -T
```

Nếu cấu hình hợp lệ, Snort sẽ báo kiểm tra thành công. Nếu lỗi, cần đọc dòng báo lỗi để sửa đường dẫn rule, cú pháp rule hoặc biến mạng.

4.5. Chạy Snort ở chế độ IDS

```
sudo snort -c /usr/local/etc/snort/snort.lua -i eth0 -A alert_fast
```

Chế độ IDS phù hợp để kiểm tra rule vì Snort chỉ cảnh báo, chưa chặn lưu lượng. Nhóm nên chạy IDS trước để chắc chắn rule hoạt động đúng.

4.6. Chạy Snort ở chế độ IPS inline bằng NFQUEUE

Để Snort chặn gói tin, có thể dùng NFQUEUE kết hợp iptables. Cách này đưa gói tin vào hàng đợi để Snort xử lý trước khi quyết định cho qua hoặc drop.

```
sudo sysctl -w net.ipv4.ip_forward=1
sudo iptables -I FORWARD -j NFQUEUE --queue-num 0
sudo snort -Q --daq nfq --daq-var queue=0 -c /usr/local/etc/snort/snort.lua -A alert_fast
```

Khuyến nghị demo: Ban đầu dùng action alert để chứng minh phát hiện. Sau đó đổi alert thành drop để chứng minh khả năng IPS chặn tấn công.

4.7. Cấu trúc rule Snort cơ bản

```
action protocol source_ip source_port -> destination_ip destination_port (options)
```

Các thành phần thường gặp trong phần options gồm msg, content, sid, rev, classtype, priority, threshold/detection_filter.

```
alert icmp any any -> any any (msg:"ICMP detected"; sid:1000001; rev:1;)
```

5. KỊCH BẢN DEMO SNORT 3

Các kịch bản dưới đây được thiết kế để nhóm có thể demo theo thứ tự từ dễ đến khó. Mỗi kịch bản gồm mục tiêu, chuẩn bị, lệnh tấn công, rule Snort và kết quả mong đợi.

5.1. Demo 1 - Phát hiện Ping ICMP

Mục tiêu: Chứng minh Snort có thể phát hiện gói ICMP khi máy Attacker ping máy Victim.

Chuẩn bị: Từ Kali Linux ping đến Victim.

Lệnh thực hiện:

```
ping 192.168.57.20
```

Rule Snort đề xuất:

```
alert icmp any any -> any any (msg:"DEMO ICMP Ping detected"; sid:1000001; rev:1;)
```

Kết quả mong đợi: Snort hiển thị cảnh báo "DEMO ICMP Ping detected". Khi chuyển alert thành drop ở chế độ inline, ping sẽ bị mất gói hoặc không phản hồi.

5.2. Demo 2 - Phát hiện TCP SYN Scan bằng Nmap

Mục tiêu: Phát hiện hành vi quét cổng SYN scan, một bước trinh sát phổ biến trước khi tấn công.

Chuẩn bị: Từ Kali Linux chạy Nmap đến Victim.

Lệnh thực hiện:

```
sudo nmap -sS -Pn 192.168.57.20
```

Rule Snort đề xuất:

```
alert tcp any any -> any any (flags:S; msg:"DEMO Possible SYN scan"; sid:1000002; rev:1;)
```

Kết quả mong đợi: Snort sinh nhiều cảnh báo SYN. Khi trình bày, nhóm cần giải thích rule đơn giản này có thể tạo false positive và nên cải tiến bằng threshold.

5.3. Demo 3 - Phát hiện SSH Brute Force

Mục tiêu: Phát hiện nhiều kết nối SSH liên tiếp từ cùng một nguồn trong thời gian ngắn.

Chuẩn bị: Victim bật dịch vụ SSH. Kali có file mật khẩu thử nghiệm pass.txt.

Lệnh thực hiện:

```
hydra -l root -P pass.txt ssh://192.168.57.20
```

Rule Snort đề xuất:

```
alert tcp any any -> any 22 (msg:"DEMO SSH brute force attempt"; flow:to_server; flags:S;  
detection_filter:track by_src, count 5, seconds 60; sid:1000003; rev:1;)
```

Kết quả mong đợi: Sau khi có nhiều kết nối tới cổng 22, Snort cảnh báo brute force. Có thể đổi action thành drop để chặn kết nối mới trong demo IPS.

5.4. Demo 4 - Phát hiện SQL Injection cơ bản

Mục tiêu: Phát hiện payload SQL Injection đơn giản trong request HTTP.

Chuẩn bị: Victim chạy DVWA hoặc web form kiểm thử. Kali gửi payload vào URL/form.

Lệnh thực hiện:

```
curl "http://192.168.57.20/dvwa/vulnerabilities/sqli/?id=' OR '1'='1&Submit=Submit"
```

Rule Snort đề xuất:

```
alert tcp any any -> any 80 (msg:"DEMO SQL Injection pattern"; flow:to_server,established; content:" OR '1'='1"; nocase; sid:1000004; rev:1;)
```

Kết quả mong đợi: Snort cảnh báo khi request chứa chuỗi payload. Cần nhấn mạnh đây là rule demo, không bao phủ mọi biến thể SQL Injection.

5.5. Demo 5 - Chặn Ping bằng IPS rule drop

Mục tiêu: Chứng minh sự khác nhau giữa IDS và IPS bằng cách chặn ICMP.

Chuẩn bị: Snort chạy inline qua NFQUEUE. iptables đã đưa FORWARD vào NFQUEUE.

Lệnh thực hiện:

```
ping 192.168.57.20
```

Rule Snort đề xuất:

```
drop icmp any any -> any any (msg:"DEMO IPS Block ICMP"; sid:1000005; rev:1;)
```

Kết quả mong đợi: Máy Attacker không nhận phản hồi ping. Snort ghi log sự kiện drop. Đây là demo rõ nhất để chứng minh IPS hoạt động.

5.6. Demo 6 - Chặn truy cập URL nhạy cảm

Mục tiêu: Chặn request HTTP chứa đường dẫn quản trị hoặc chuỗi đáng ngờ.

Chuẩn bị: Victim chạy web server; Attacker truy cập đường dẫn /admin hoặc /phpmyadmin.

Lệnh thực hiện:

```
curl http://192.168.57.20/admin
```

Rule Snort đề xuất:

```
drop tcp any any -> any 80 (msg:"DEMO Block access to admin path"; flow:to_server,established; http_uri;
```

Kết quả mong đợi: Request bị chặn khi Snort chạy inline. Trình duyệt/curl có thể timeout hoặc không nhận phản hồi hợp lệ.

6. ĐÁNH GIÁ HỆ THỐNG

6.1. Tiêu chí đánh giá

- Khả năng phát hiện: rule có sinh cảnh báo đúng khi có hành vi tấn công hay không.
- Khả năng ngăn chặn: rule drop có chặn được lưu lượng trong chế độ inline hay không.
- Độ ổn định: Snort có chạy ổn định trong thời gian demo không.
- False positive: rule có cảnh báo nhầm lưu lượng hợp lệ không.
- Dễ quản trị: cấu hình, rule và log có dễ kiểm tra, chỉnh sửa không.

6.2. Ưu điểm

- Mã nguồn mở, dễ tiếp cận cho học tập và nghiên cứu.
- Rule linh hoạt, có thể tự viết theo nhu cầu.
- Hỗ trợ nhiều chế độ hoạt động, từ giám sát đến chặn inline.
- Cộng đồng sử dụng rộng, có nhiều tài liệu tham khảo.

6.3. Hạn chế

- Cần hiểu rõ mạng, giao thức và cú pháp rule để cấu hình hiệu quả.
- Rule đơn giản có thể gây false positive hoặc bỏ sót biến thể tấn công.
- Chế độ inline có thể ảnh hưởng lưu lượng nếu cấu hình sai.
- Hiệu năng phụ thuộc phần cứng, lưu lượng mạng và số lượng rule.

6.4. Biện pháp cải tiến

- Tinh chỉnh rule bằng flow, threshold, detection_filter để giảm cảnh báo nhầm.
- Phân tách rule demo và rule vận hành.
- Tích hợp dashboard như ELK, Splunk hoặc Grafana để quan sát log trực quan.
- Tự động cập nhật rule cộng đồng và kiểm thử rule trước khi áp dụng vào IPS inline.

7. KẾT LUẬN VÀ HƯỚNG PHÁT TRIỂN

7.1. Kết luận

Đồ án đã trình bày quá trình xây dựng hệ thống IPS sử dụng Snort 3 trong môi trường lab. Hệ thống có thể phát hiện các hành vi cơ bản như ping, quét cổng, brute force SSH, SQL Injection và có thể chặn gói tin khi hoạt động ở chế độ inline với rule drop.

Thông qua đồ án, nhóm nắm được quy trình thiết kế mô hình mạng, cài đặt Snort, viết rule, kiểm thử cảnh báo và đánh giá kết quả. Đây là nền tảng để phát triển các giải pháp giám sát và phòng thủ mạng nâng cao hơn.

7.2. Hướng phát triển

- Tích hợp Snort với hệ thống SIEM để phân tích log tập trung.
- Xây dựng dashboard trực quan cho cảnh báo.
- Nghiên cứu rule nâng cao cho HTTP, DNS, malware traffic.
- So sánh hiệu năng Snort 3 với Suricata trong cùng mô hình.
- Tự động hóa triển khai bằng script hoặc Ansible.

8. PHÂN CÔNG CÔNG VIỆC CHO 4 THÀNH VIÊN

Thành viên	Phụ trách chính	Nội dung thực hiện	Sản phẩm bàn giao
Người 1	Cơ sở lý thuyết	Chương 1, Chương 2: IDS/IPS, Snort 3, nguyên lý hoạt động	Nội dung lý thuyết, bảng so sánh IDS/IPS
Người 2	Thiết kế hệ thống	Chương 3: mô hình mạng, vai trò máy, luồng hoạt động	Sơ đồ mạng, bảng IP, mô tả kiến trúc
Người 3	Triển khai Snort	Chương 4: cài đặt, cấu hình, chạy IDS/IPS	Hướng dẫn cài đặt, ảnh chụp terminal, file rule
Người 4	Demo và đánh giá	Chương 5, 6, 7: kịch bản demo, kết quả, đánh giá	Video/ảnh demo, bảng kết quả, kết luận

9. BẢNG KẾ HOẠCH THỰC HIỆN

Giai đoạn	Công việc	Người phụ trách	Kết quả
Tuần 1	Tìm hiểu lý thuyết IDS/IPS, Snort 3	Người 1	Nội dung chương 1-2
Tuần 2	Dựng mô hình mạng lab	Người 2	Máy ảo, IP, sơ đồ mạng

Tuần 3	Cài đặt và cấu hình Snort 3	Người 3	Snort chạy IDS/IPS
Tuần 4	Viết rule và chạy demo	Người 3, 4	Log, ảnh chụp, video demo
Tuần 5	Hoàn thiện báo cáo và slide	Cả nhóm	Báo cáo hoàn chỉnh

10. MẪU BẢNG GHI NHẬN KẾT QUẢ DEMO

STT	Kịch bản	Rule SID	Kết quả IDS	Kết quả IPS	Ghi chú
1	ICMP Ping	1000001	Có/Không	Chặn/Không chặn	Ảnh log minh chứng
2	TCP SYN Scan	1000002	Có/Không	Chặn/Không chặn	Ảnh log minh chứng
3	SSH Brute Force	1000003	Có/Không	Chặn/Không chặn	Ảnh log minh chứng
4	SQL Injection	1000004	Có/Không	Chặn/Không chặn	Ảnh log minh chứng
5	Block ICMP	1000005	Có/Không	Chặn/Không chặn	Ảnh log minh chứng
6	Block admin URL	1000006	Có/Không	Chặn/Không chặn	Ảnh log minh chứng

11. TÀI LIỆU THAM KHẢO

1. Snort 3 Official Documentation - Cisco Talos.
2. Snort Rule Writing Guide - Cisco Talos.
3. OWASP Top 10 - Open Worldwide Application Security Project.
4. NIST Cybersecurity Framework.
5. Tài liệu học phần An toàn mạng / An ninh hệ thống.

PHỤ LỤC A. DANH SÁCH RULE DEMO TỔNG HỢP

```
alert icmp any any -> any any (msg:"DEMO ICMP Ping detected"; sid:1000001; rev:1;)
alert tcp any any -> any any (flags:S; msg:"DEMO Possible SYN scan"; sid:1000002; rev:1;)
alert tcp any any -> any 22 (msg:"DEMO SSH brute force attempt"; flow:to_server; flags:S;
detection_filter:track by_src, count 5, seconds 60; sid:1000003; rev:1;)
alert tcp any any -> any 80 (msg:"DEMO SQL Injection pattern"; flow:to_server,established; content:" OR
'1'='1"; nocase; sid:1000004; rev:1;)
drop icmp any any -> any any (msg:"DEMO IPS Block ICMP"; sid:1000005; rev:1;)
drop tcp any any -> any 80 (msg:"DEMO Block access to admin path"; flow:to_server,established; http_uri;
content: "/admin"; sid:1000006; rev:1;)
```

PHỤ LỤC B. CHECKLIST TRƯỚC KHI DEMO

- Các máy ảo ping được nhau theo đúng mô hình.
- Snort kiểm tra cấu hình bằng lệnh -T không báo lỗi.
- File local.rules đã được include trong snort.lua.
- iptables/NFQUEUE đã được cấu hình khi demo IPS.
- Đã chuẩn bị ảnh chụp màn hình log cho trường hợp demo trực tiếp bị lỗi.
- Mỗi thành viên nắm rõ phần trình bày của mình.